



VIT[®]

Vellore Institute of Technology

(Deemed to be University under section 3 of UGC Act, 1956)

School of Computer Science and Engineering

BCSE309L – Cryptography and Network Security

Module ~ IV – Message Digest and Hash Functions

Hash functions, Message Authentication, Message Authentication Code (MAC)

Presentation by

Dr.K.Ragavan

Assistant Professor Senior Grade I

Department of IOT

School of Computer Science and Engineering

VIT University, Vellore

SYLLABUS

Module:1

Fundamentals of Number Theory

5 hours

Finite Fields and Number Theory: Modular arithmetic, Euclidian Algorithm, Primality Testing: Fermats and Eulers theorem, Chinese Reminder theorem, Discrete Logarithms

Module:2

Symmetric Encryption Algorithms

7 hours

DES, AES,IDEA, Block Cipher Operation, Random Bit Generation and RC4.

Module:3

Asymmetric Encryption Algorithm and Key Exchange

8 hours

Asymmetric key cryptographic techniques: principles, RSA, ElGamal, Elliptic Curve cryptography, Homomorphic Encryption and Secret Sharing, Key distribution and Key exchange protocols, Diffie-Hellman Key Exchange, Man-in-the-Meddle Attack.

SYLLABUS

Module:4

Message Digest and Hash Functions

5 hours

Requirements for Hash Functions, Security of Hash Functions, Message Digest (MD5), Secure Hash Function (SHA), Birthday Attack, HMAC.

Module:5

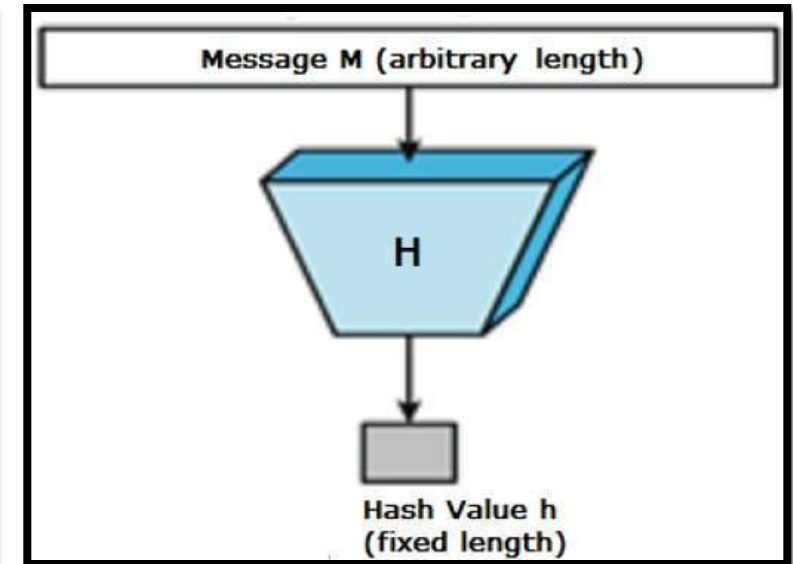
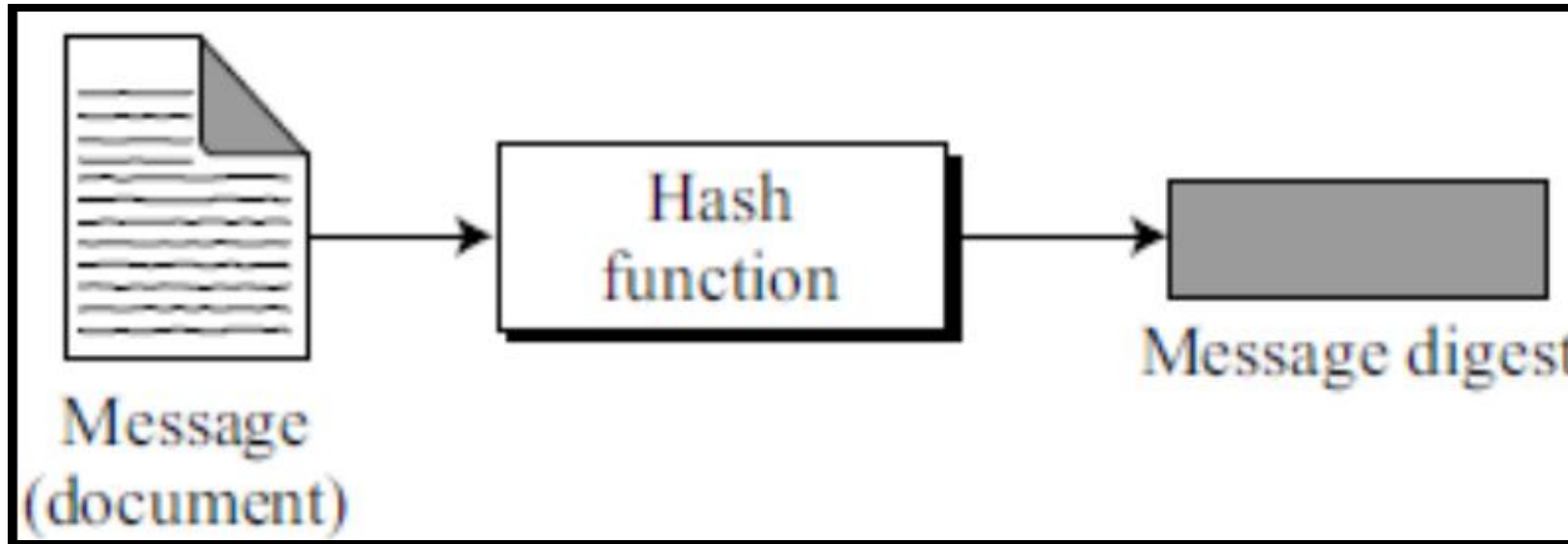
Digital Signature and Authentication Protocols

7 hours

Authentication Requirements, Authentication Functions, Message Authentication Codes, Digital Signature Authentication, Authentication Protocols, Digital Signature Standards, RSA Digital Signature, Elgamal based Digital Signature, Authentication Applications: Kerberos, X.509 Authentication Service, Public Key Infrastructure (PKI)

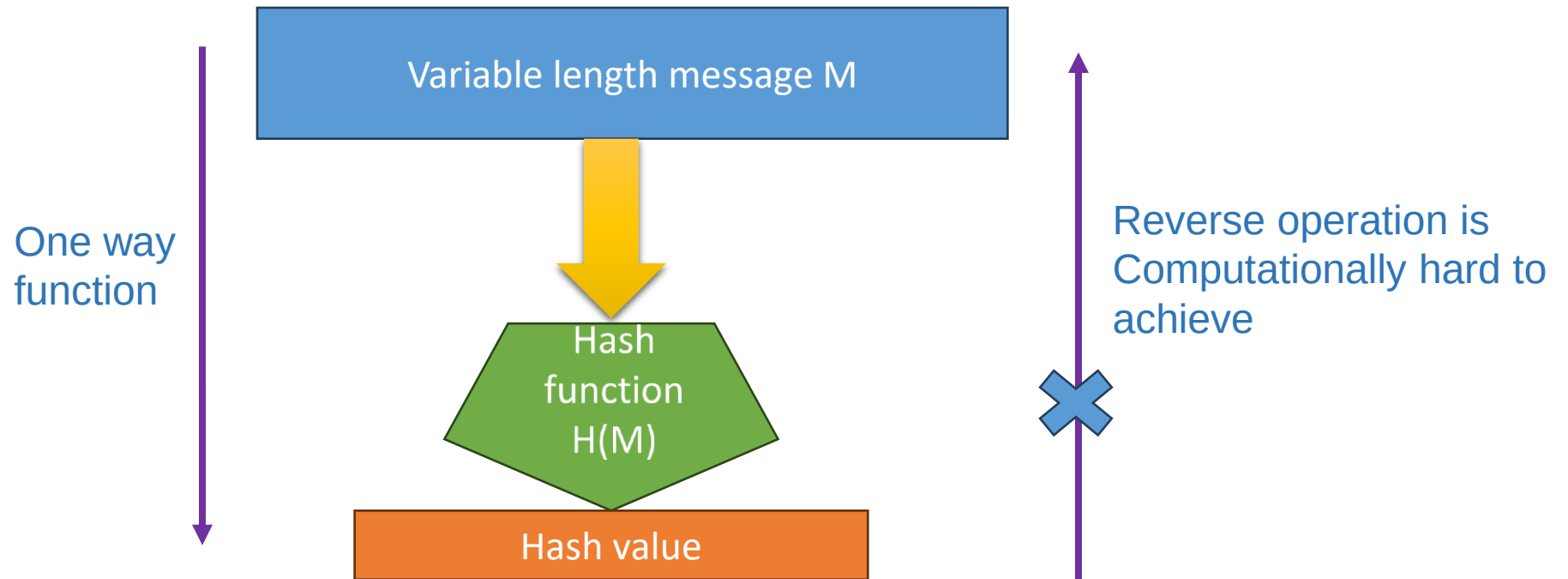
HASH FUNCTIONS

- It is used to achieve the **data integrity** (free from alteration) **and authentication** (verify the user identity).
- Hash function (h) accepts a variable length block of data (M) as input and produces fixed size of hash value (y – Message Digest/hash code)
- $y=h(M)$ or $h=H(M)$
- A cryptographic hash function (CHF) is a mathematical algorithm that maps the **given message to a bit array of a fixed size** ("hash code").
- It is a **one-way function**, which means the **produced message digest** is **irreversible**.



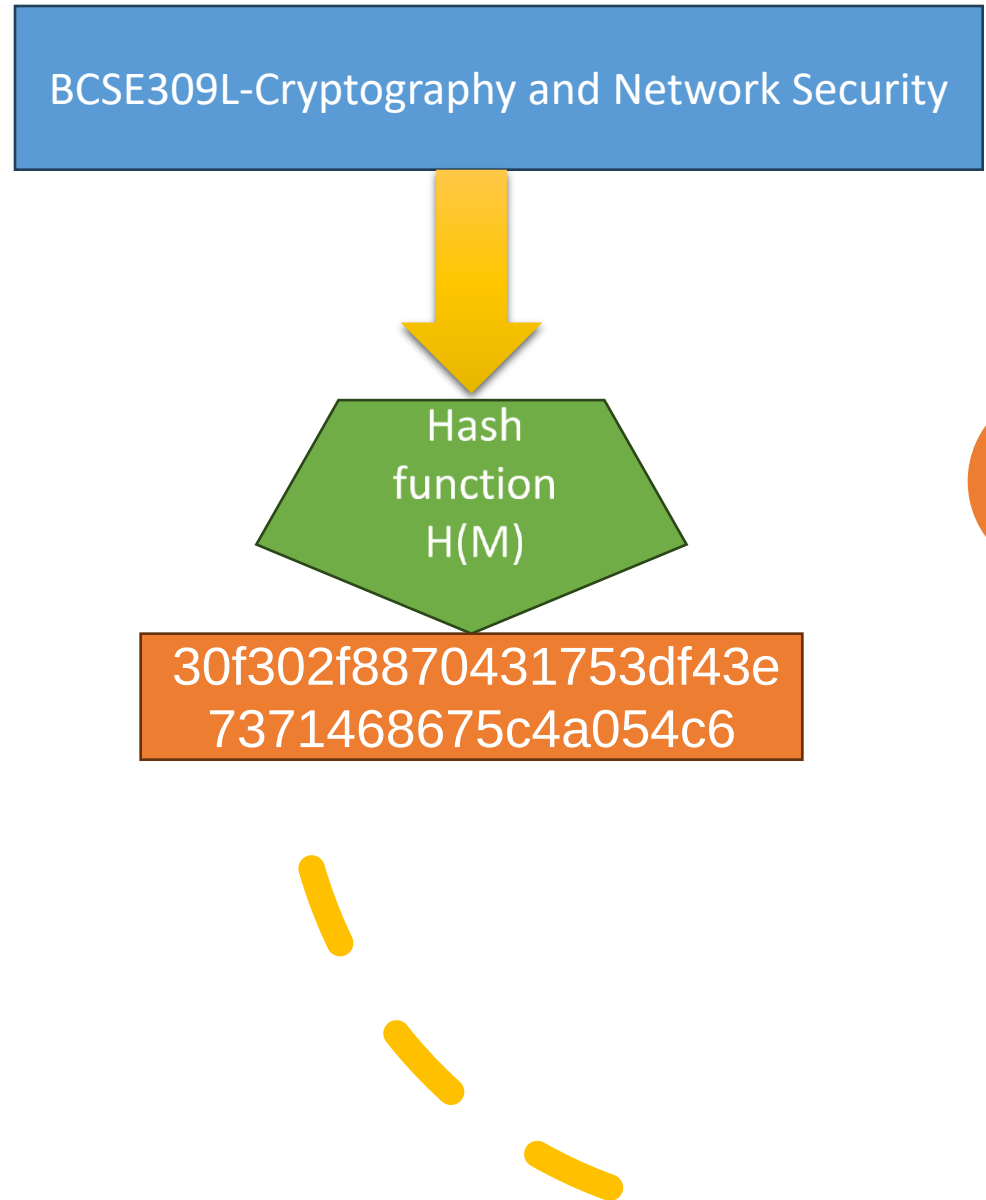
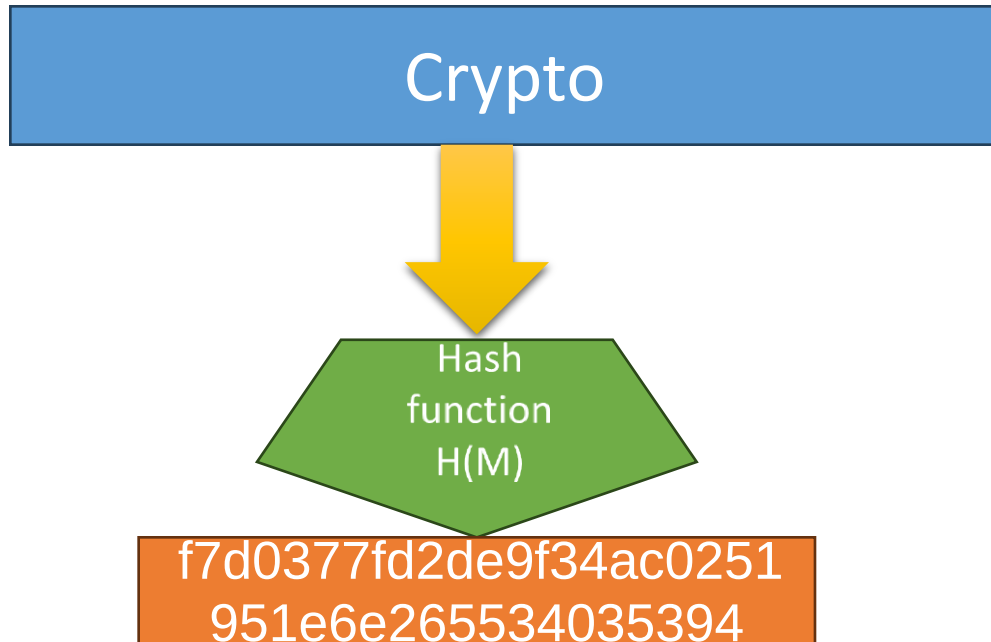
Hash function

- A hash function H accepts a variable length block of data M as Input and produces a fixed size hash value.



Hash function example

- Variable size Inputs but fixed output.



Cryptographic hash functions

- Hash functions used for security applications are known as cryptographic hash functions.

Two Important properties:-

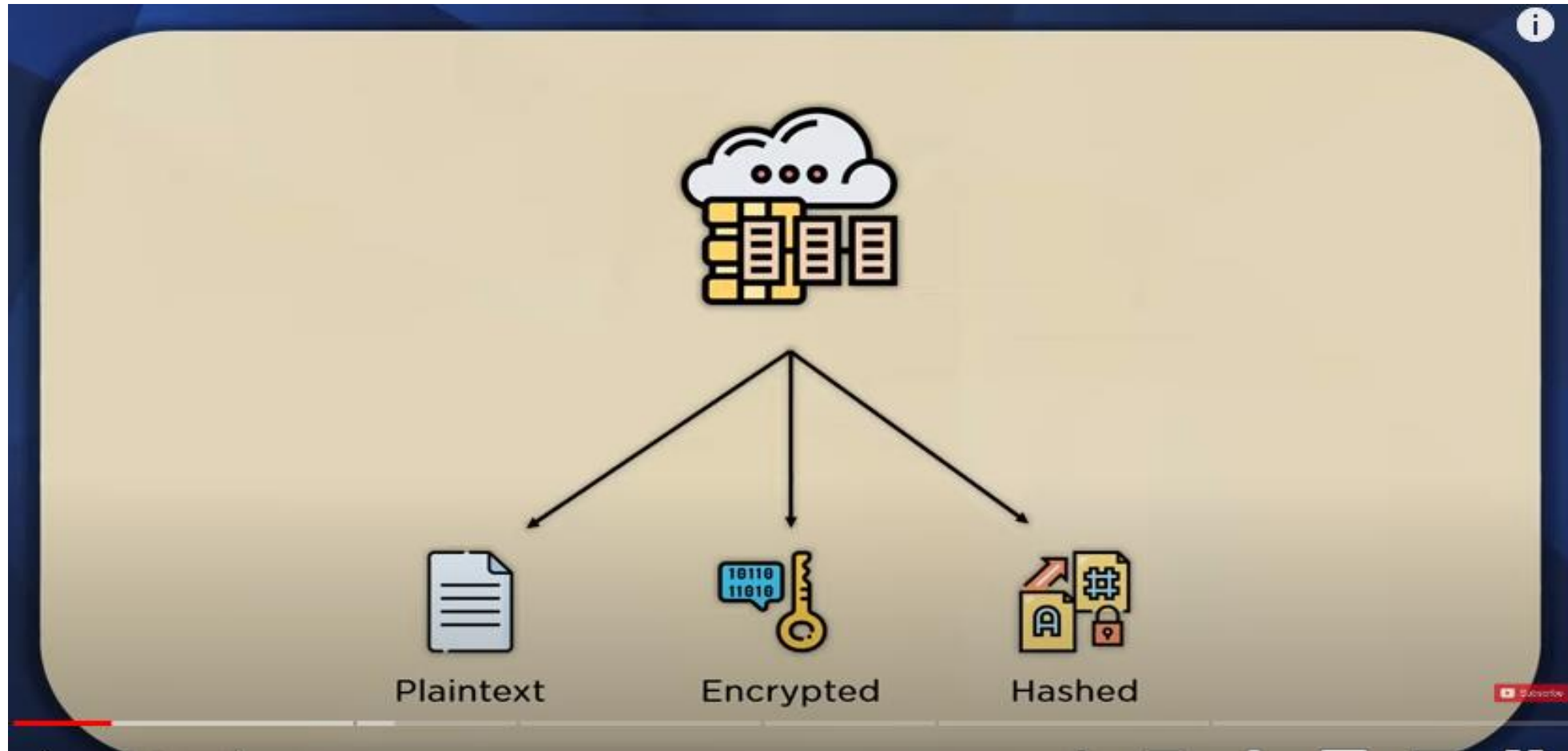
- It is computationally infeasible to find either,
 - a) a data object that maps to a pre-specified hash result
(The one-way property) or
 - b) Two data objects that map to the same hash result.
(The collision free property)

[Intruder try to detect collisions only through brute-force method.]

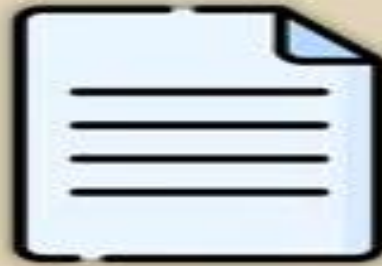
Let's say you sign up on a new website using your email id and trusted password combination. How do you think it will be stored on their servers?



Servers



Plaintext



- Very easy to gather information from.
- No security, can be reused with other websites.
- Website owner can also read personal data.

Encrypted



- More secure than plaintext.
- Decryption key is stored on servers, so it's still vulnerable.
- Once decryption key is hacked, all the encrypted passwords are broken.

Hashed



- Hashing will not reveal passwords in a data breach
- No encryption key needed
- Website owners can't read your data either

What Is Hashing?

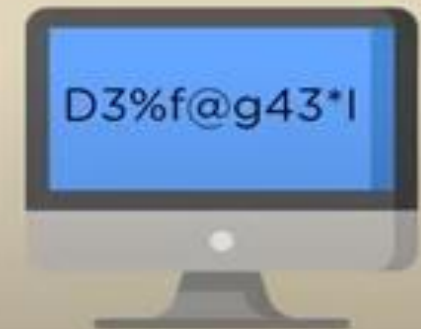
Hashing is the process of scrambling a piece of information or data beyond recognition. They are designed to be irreversible. We pass the input through a hash function to calculate the Hash Value or Digest.



Original Data



Hash Function



Hash Value/Digest

When a new user signs-up, the new password is passed through the hash function and the digest is stored on the server.



Hash stored on server



When the same user tries to log-in, the password they input is passed through the function again and the digest is compared to the one stored on the servers.



If the re-calculated hash matches the hash stored on the servers during initial sign-up, the log-in is allowed.

D3%f@g43*I

Re-calculated
Digest



D3%f@g43*I

Hash Stored on
the Servers

Login is Allowed

If the calculated digest is different from the one on the server, the login is denied from the website.

R2#h9Ln7q&

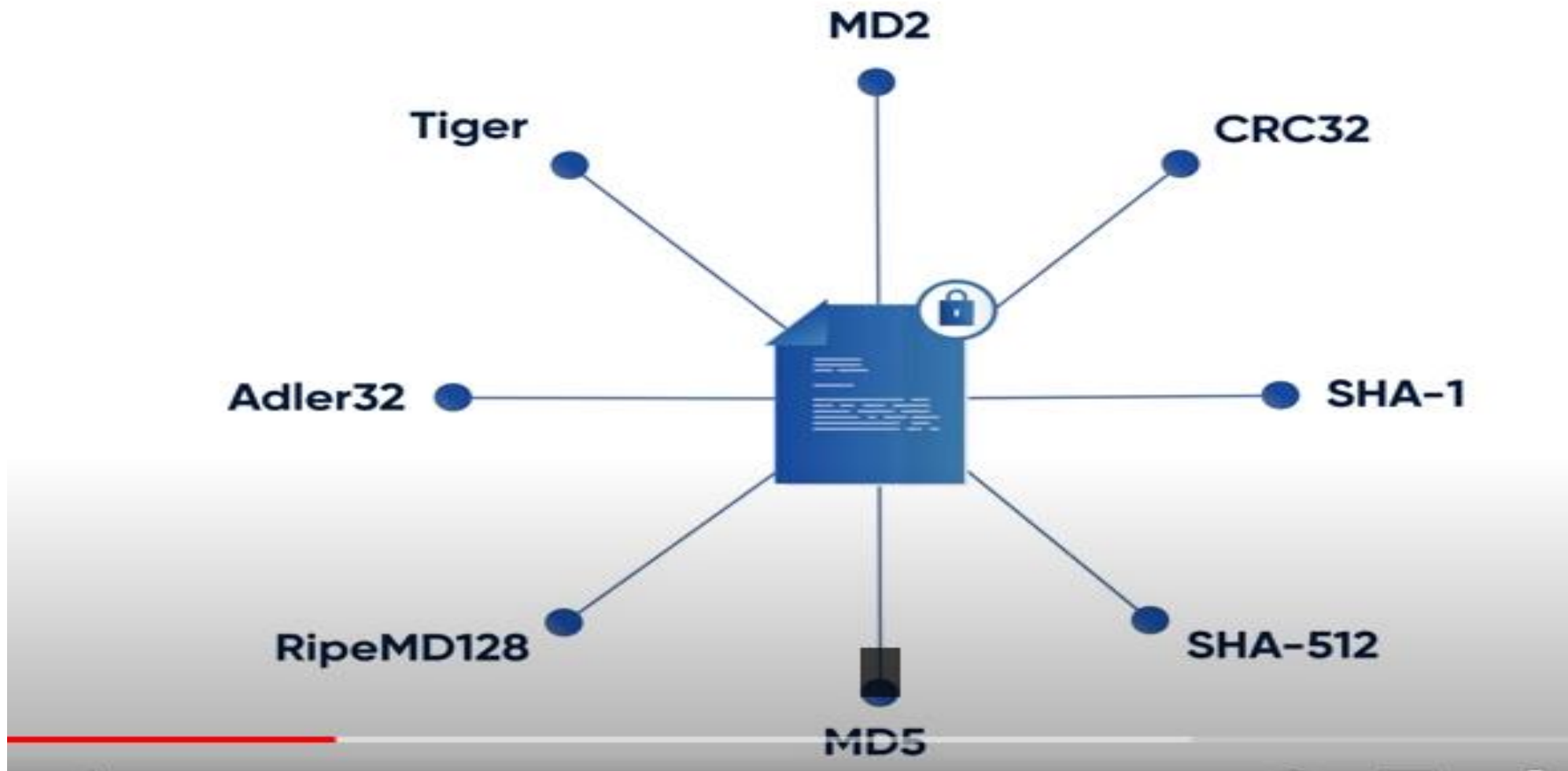
Re-calculated
Digest



D3%f@g43*I

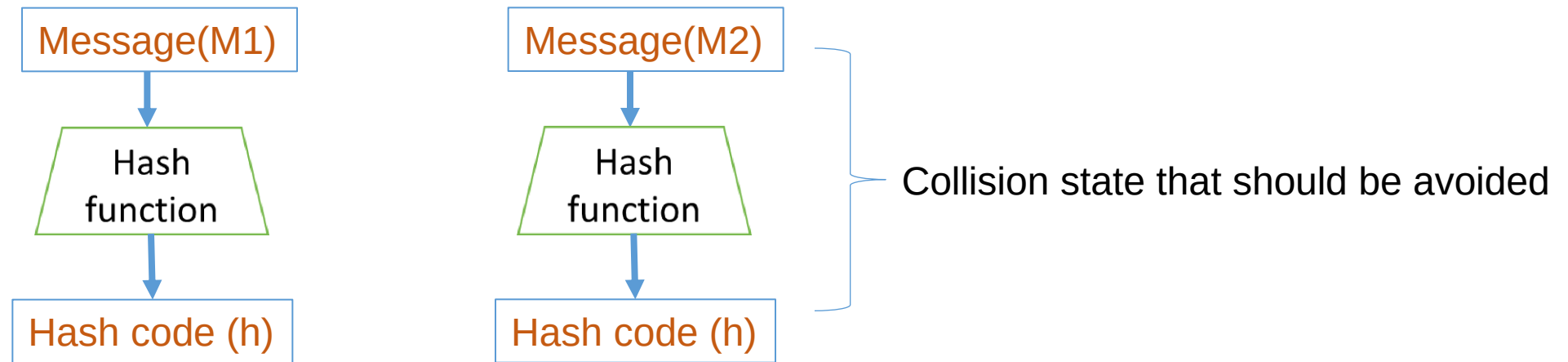
Hash Stored on
the Servers

Login is Denied



Properties of a hash function

- A good hash function has a property that the results of applying the function to a large set of inputs will produce outputs that are evenly distributed and apparently random.
- A change to any bit or bits in results, with high probability, in a change to the hash code. (**Avalanche effect**)
- Hash function should be a **collision resistant**.



Properties of hash functions

- A **cryptographic hash function** must satisfy **three criteria**
 - Preimage resistance
 - Second preimage resistance
 - Collision resistance

Pre-image Resistance

For a given hash value h , it is computationally infeasible to find a message m such that $h = \text{Hash}(m)$.

This property makes a cryptographic hash function a one-way function.

$H(\text{Ahmad}) = \text{ABC20DF} \rightarrow$ Hacker knows hash value, but he could not get its preimage

Second Pre-image Resistance

For a given message m_1 , it is computationally infeasible to find a different message m_2 such that $\text{Hash}(m_1) = \text{Hash}(m_2)$.

This property is sometimes referred to as weak collision resistance.

$H(\text{Ahmad}) = \text{ABC20DF}$ $\rightarrow$ Hacker knows hash value, but he could not find. Another preimage which gives the same hash value

$H(\text{Ragavan}) = \text{ABC20DF}$

Collision Resistance

It is computationally infeasible to find two messages m_1 and m_2 , such that
 $\text{Hash}(m_1) = \text{Hash}(m_2)$

And such a pair of messages m_1 and m_2 is called a cryptographic hash collision.

This property is sometimes referred to as strong collision resistance.

Security requirements for cryptographic hash functions

Requirement	Description
Variable size	Hash function (H) can be applied to a block of data of any size.
Fixed output size	Hash function (H) produces a fixed length output.
Efficiency	$H(x)$ is relatively easy to compute for any given x , making both hardware and software Implementations practical's.
Pre-Image resistant	For any given hash value h , it is computationally infeasible to find y such that $H(y) = h$.
Second pre-Image resistant (weak collision resistant)	For any given block x , it is computationally infeasible to find $y \neq x$ with $H(y) = H(x)$.
Collision resistant (Strong collision resistant)	It is computationally infeasible to find any pair (x , y) such that $H(x) = H(y)$.
Pseudorandomness	Output of Hash function (H) meets standard tests for pseudorandomness.

APPLICATION OF HASH FUNCTIONS

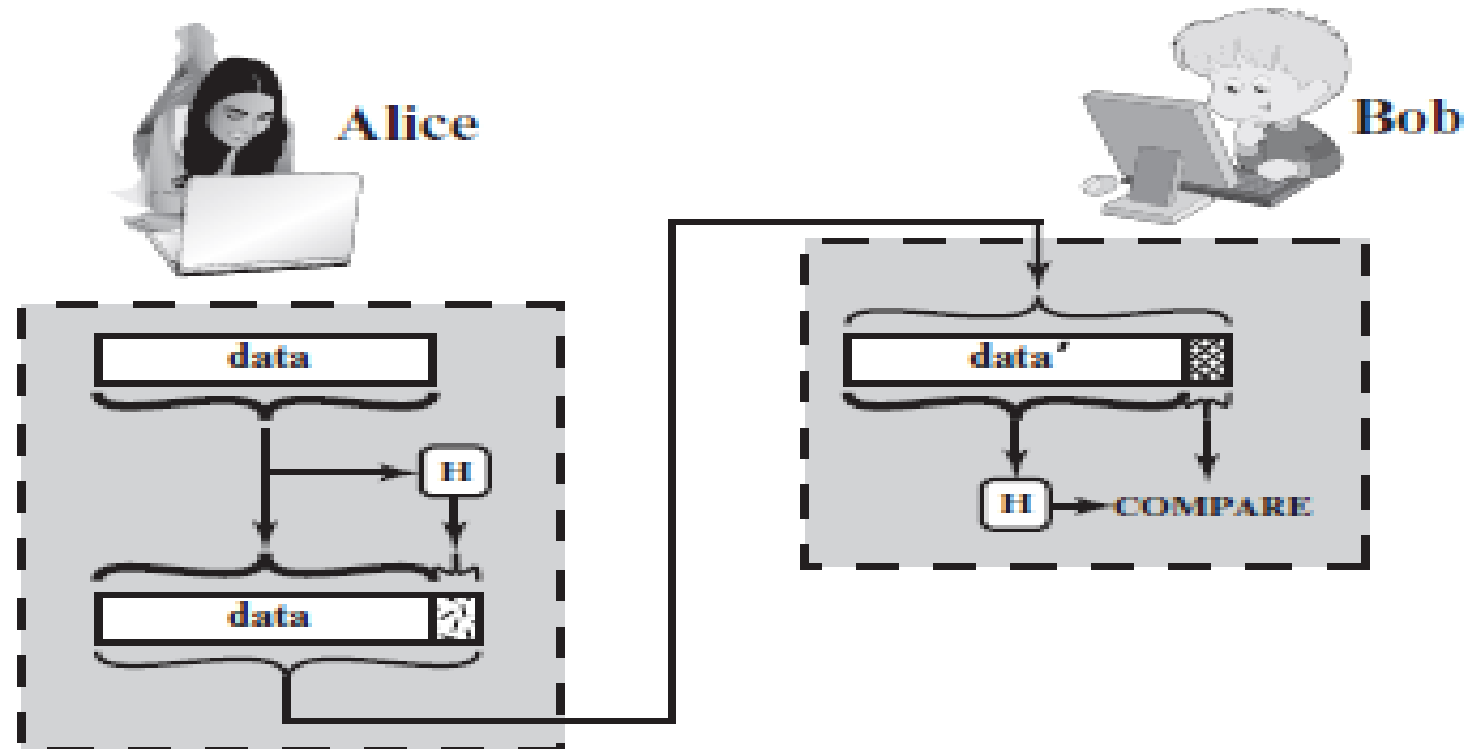
- **In Cryptography**
 - Message Authentication
 - Digital Signatures
 - One way password file
 - Intrusion Detection and Prevention

Message Authentication

- Message authentication is a mechanism or service **used to verify the integrity of a message**. Message authentication assures that data received are exactly as sent (i.e., there is no modification, insertion, deletion, or replay).
- In many cases, there is a requirement that the authentication mechanism assures that purported identity of the sender is valid.
- When a hash function is used to provide message authentication, **the hash function value is often referred to as a message digest**.

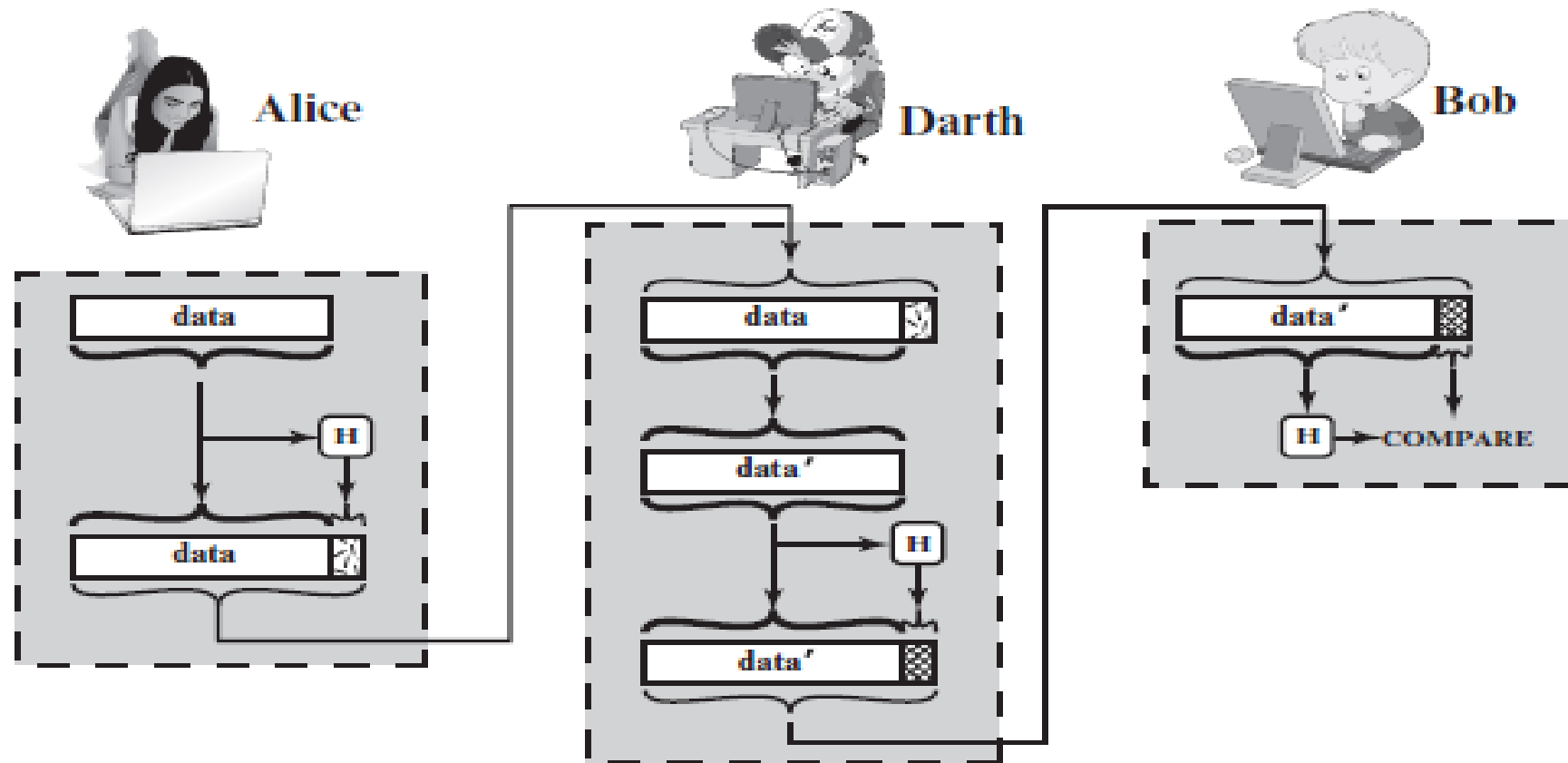


Use of hash function to check data integrity



Attack Against Hash Function

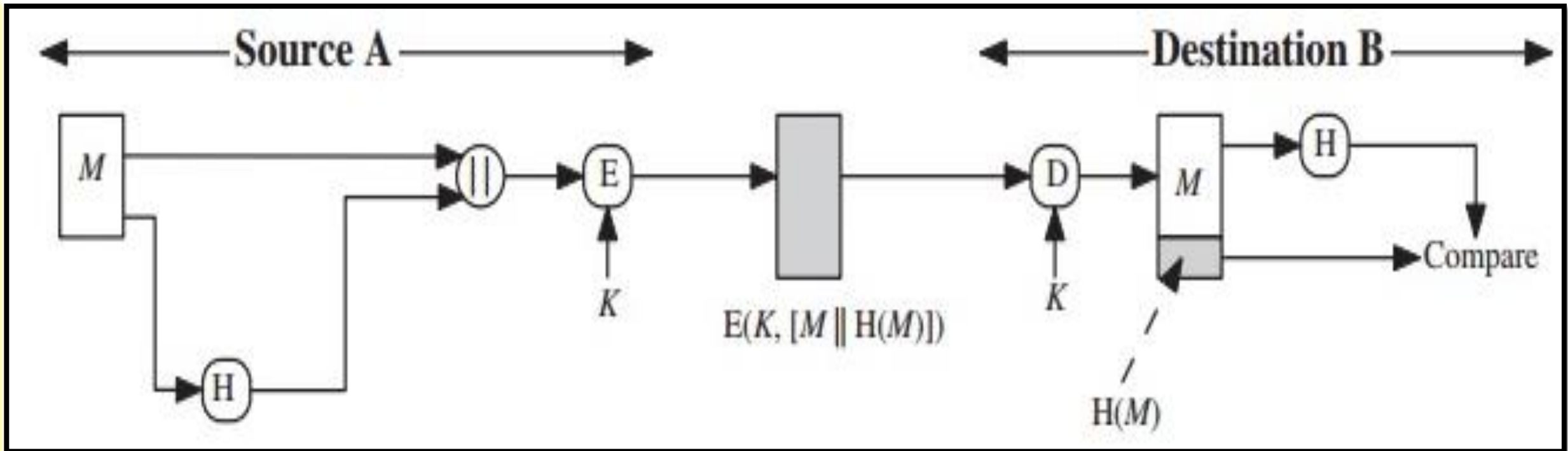
Man-in-the-middle attack



Simplified Examples of the Use of a Hash Function for Message Authentication

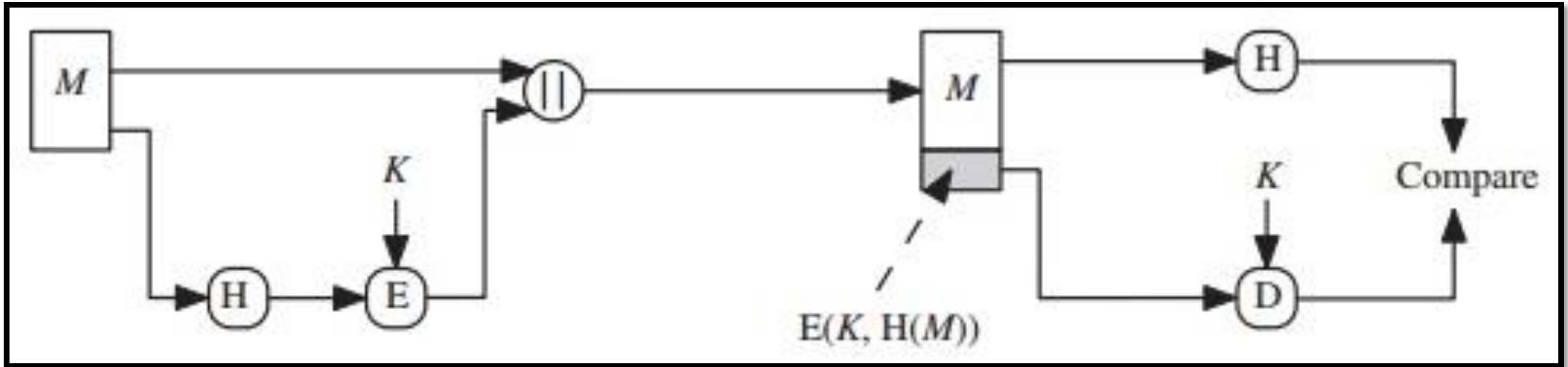
• Scenario 1:

- The message (M) plus concatenated hash code is encrypted using symmetric encryption.
- Because only A and B share the secret key, the M must have come from A and has not been altered.
- Encryption is applied to the entire M plus hash code, **confidentiality is achieved**.



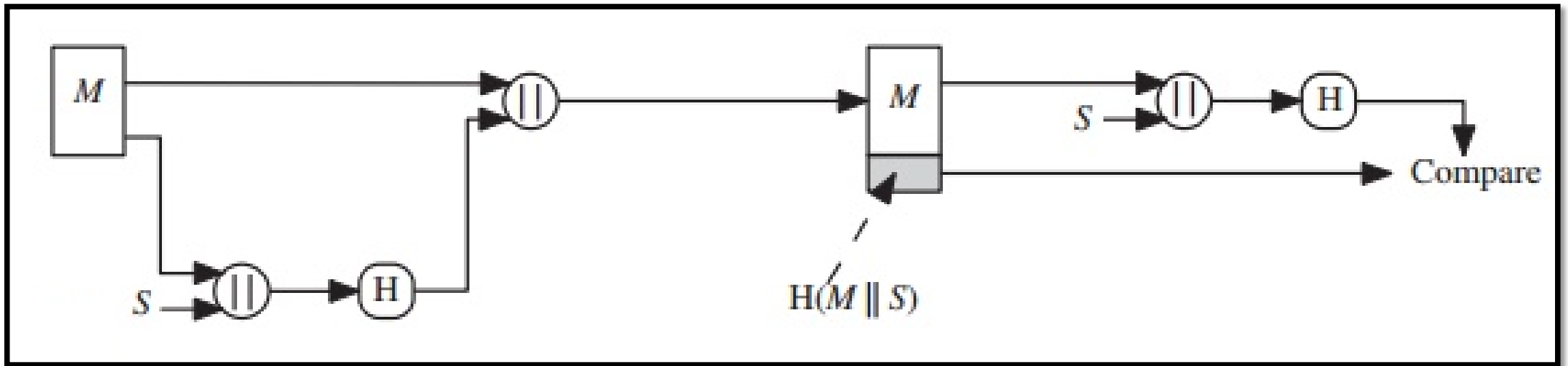
- **Scenario 2:**

- Only the hash code is encrypted, using symmetric encryption. This reduces the processing burden for those applications that **do not require confidentiality**.

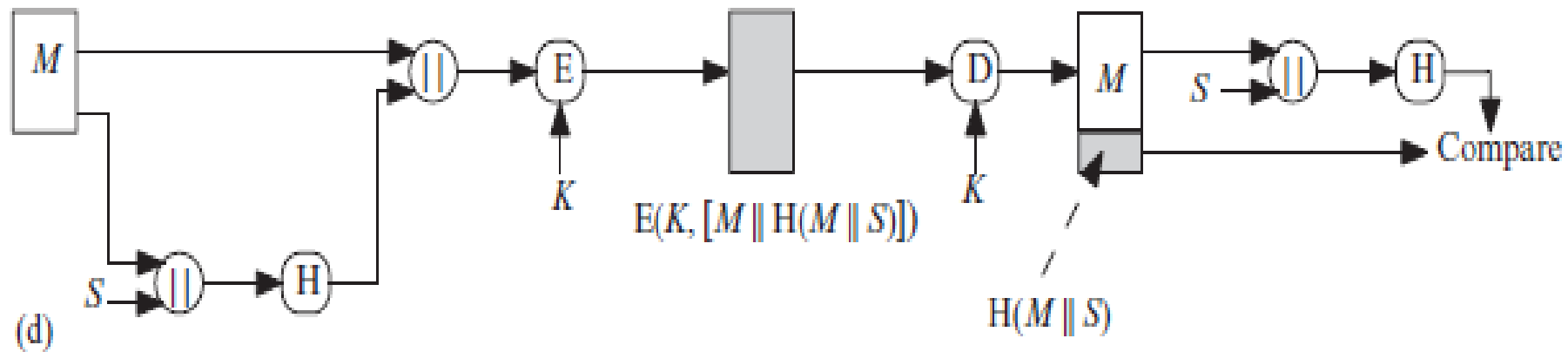


• Scenario 3:

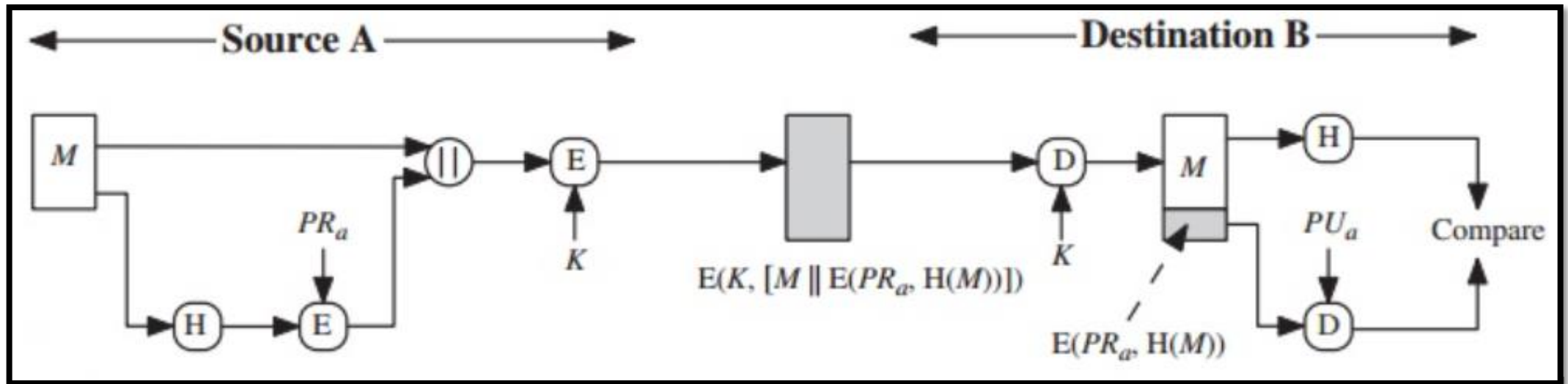
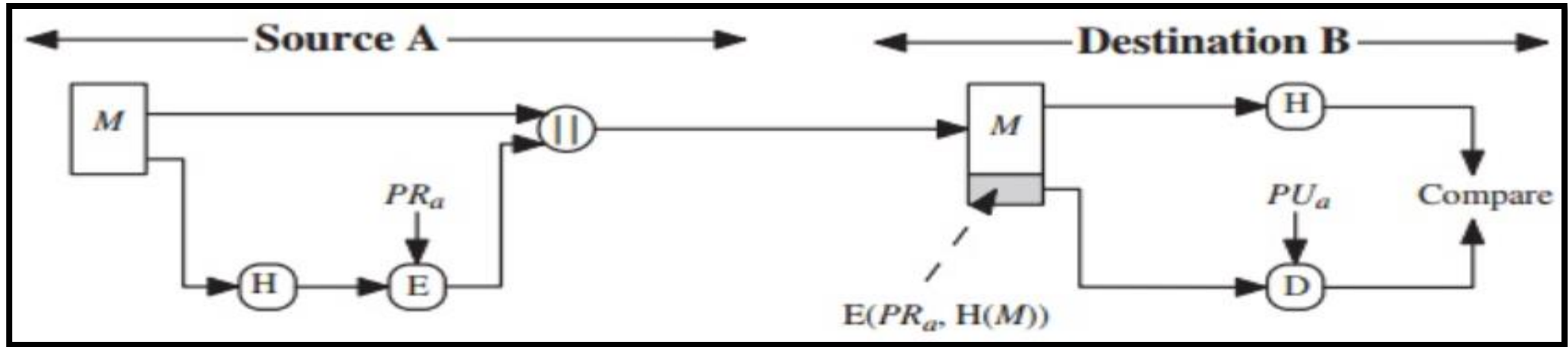
- The two communicating parties share a common secret value S .
- A computes the hash value over the concatenation of M and S and appends the resulting hash value to M .
- Because B possesses S , B can recompute the hash value to verify.
- Because the secret value is not sent.



- **Scenario 4:**
- Confidentiality can be added in scenario 3 by encrypting the entire message plus the hash code.



Other Scenarios - Digital Signatures



Message Authentication Requirements

1. **Disclosure:** Release of message contents to any person or process not possessing the appropriate cryptographic key.
2. **Traffic analysis:** Discovery of the pattern of traffic between parties. In a connection-oriented application, the frequency and duration of connections could be determined. In either a connection-oriented or connectionless environment, the number and length of messages between parties could be determined.
3. **Masquerade:** Insertion of messages into the network from a fraudulent source.
4. **Content modification:** Changes to the contents of a message, including insertion, deletion, transposition, and modification.
5. **Sequence modification:** Any modification to a sequence of messages between parties, including insertion, deletion, and reordering.

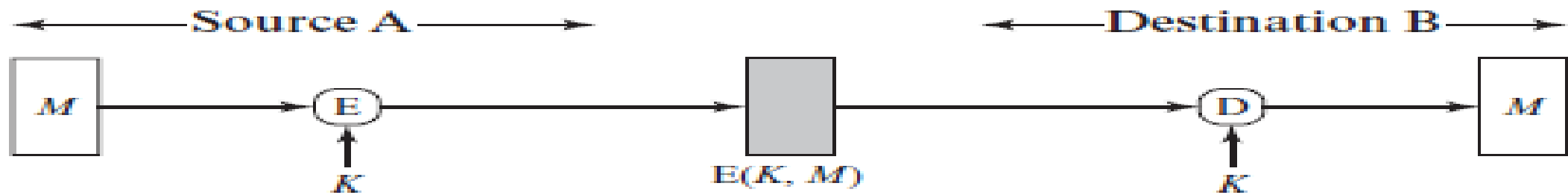
6. **Timing modification:** Delay or replay of messages. In a connection-oriented application, an entire session or sequence of messages could be a replay of some previous valid session, or individual messages in the sequence could be delayed or replayed. In a connectionless application, an individual message (e.g., datagram) could be delayed or replayed.
7. **Source repudiation:** Denial of transmission of message by source.
8. **Destination repudiation:** Denial of receipt of message by destination.

Message Authentication Functions

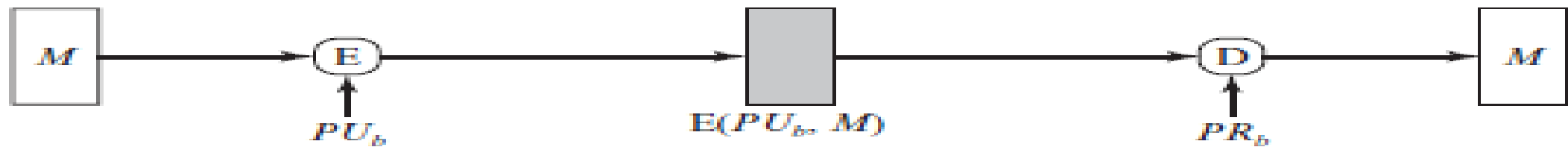
These may be grouped into three classes.

- **Hash function:** A function that maps a message of any length into a fixed-length hash value, which serves as the authenticator
- **Message encryption:** The ciphertext of the entire message serves as its authenticator
- **Message authentication code (MAC):** A function of the message and a secret key that produces a fixed-length value that serves as the authenticator

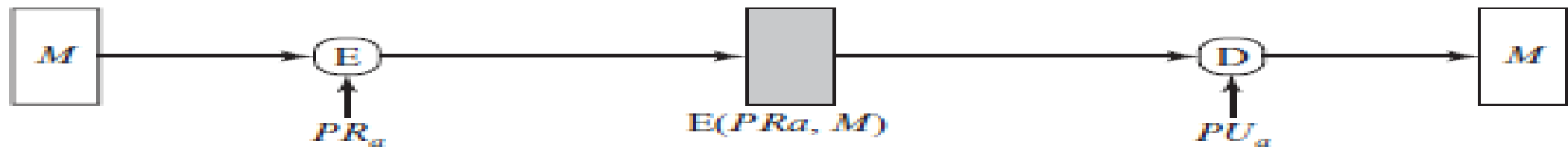
Message Encryption



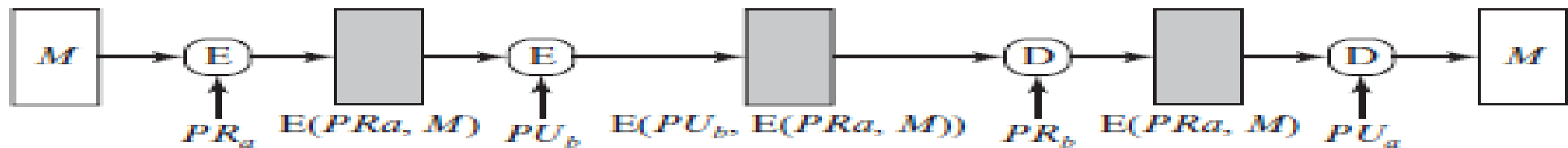
(a) Symmetric encryption: confidentiality and authentication



(b) Public-key encryption: confidentiality



(c) Public-key encryption: authentication and signature

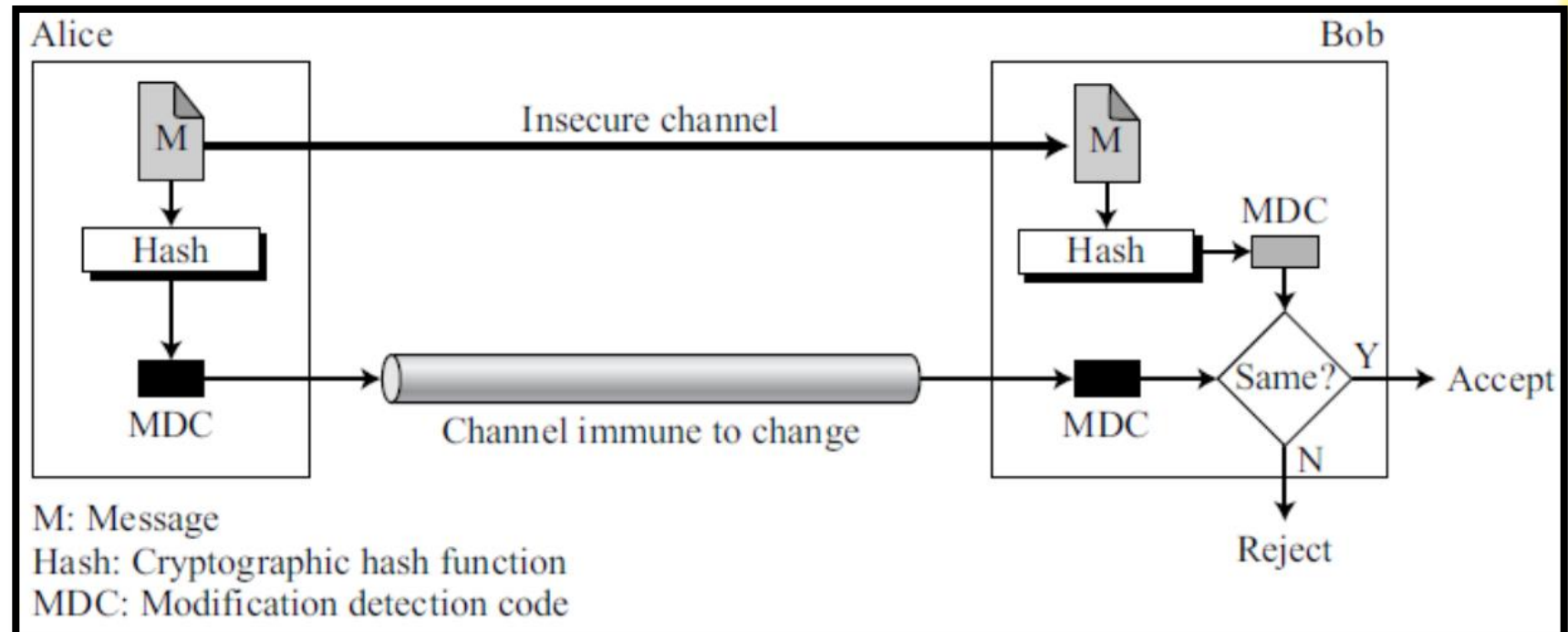


(d) Public-key encryption: confidentiality, authentication, and signature

Figure 12.1 Basic Uses of Message Encryption

MESSAGE AUTHENTICATION CODE

- A message digest guarantees the integrity of a message.
- It guarantees that the message has not been changed.
- Message authentication is provided in two ways
 - Modification Detection Code (MDC)
 - Message Authentication Code (MAC)
- **Modification Detection Code (MDC)**
- It is a message digest that can prove the integrity of the message: that message has not been changed.



Cont..

- To ensure the **integrity of the message and the data origin authentication**, we moved on from modification detection code (MDC) to a message authentication code (MAC). **No Confidentiality!!!!**
- More commonly, message authentication is achieved using a **message authentication code (MAC) or cryptographic checksum, or keyed hash function**
- Typically, MACs are used between two parties that **share a secret key** to authenticate information exchanged between those parties.
- A MAC function takes as input a secret key and a data block and produces a hash value, **referred to as the MAC**, which is associated with the protected message.
- If the integrity of the message needs to be checked, the MAC function can be applied to the message and the result compared with the associated MAC value.
- An attacker who alters the **message will be unable to alter the associated MAC value without knowledge of the secret key.**
- In practice, specific MAC algorithms are designed that are generally **more efficient than an encryption algorithm.**

1. The receiver is assured that the message has not been altered.

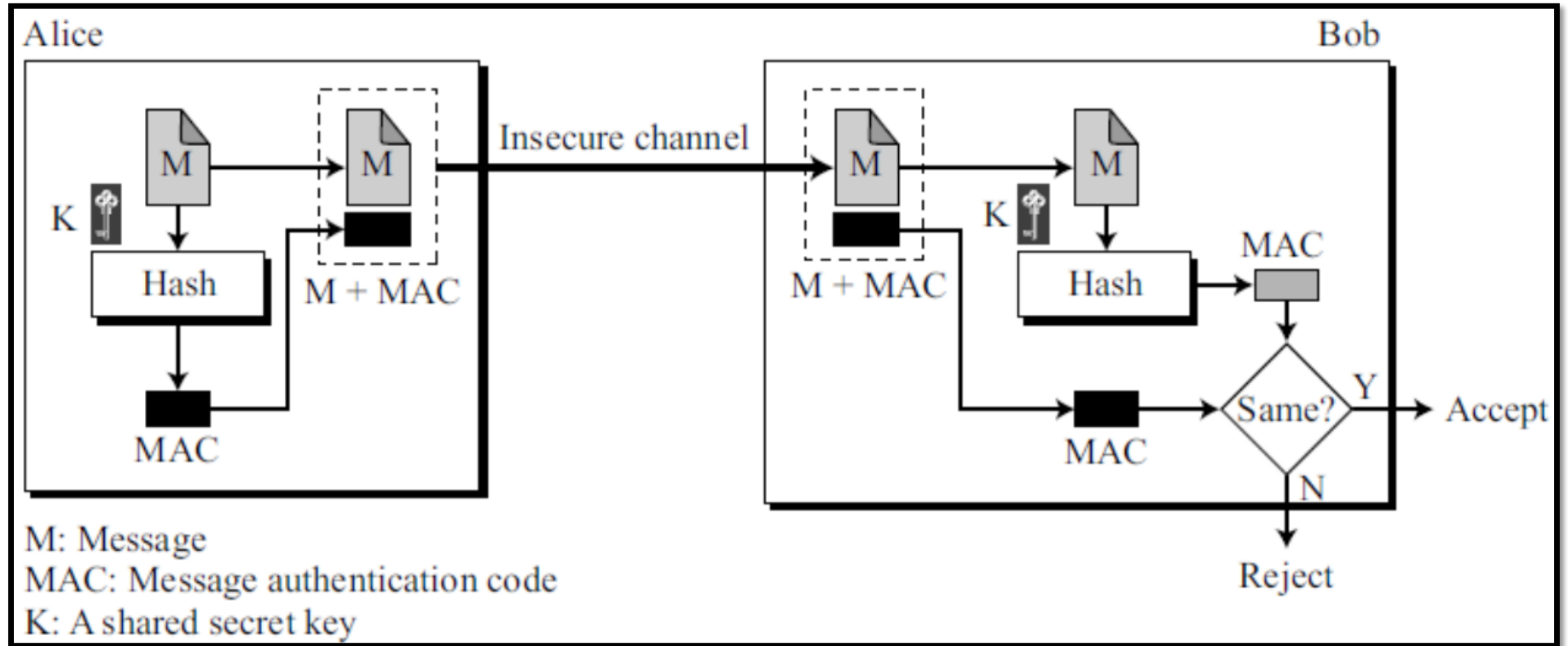
- If an attacker alters the message but does not alter the MAC, then the receiver's calculation of the MAC will differ from the received MAC.
- Because the attacker is assumed not to know the secret key, the attacker cannot alter the MAC to correspond to the alterations in the message.

2. The receiver is assured that the message is from the attacker.

Because no one else knows the secret key, no one else could prepare a message with a proper MAC.

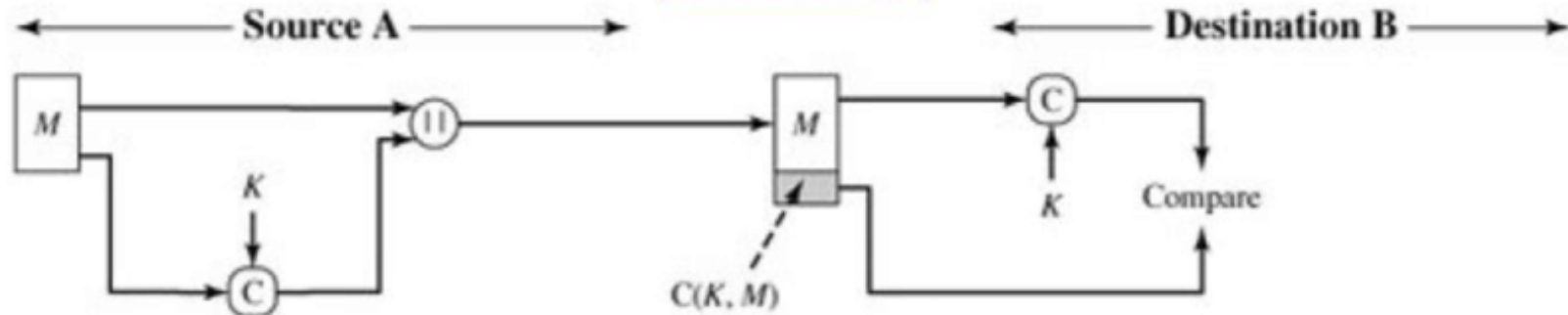
- A MAC function is similar to encryption. One difference is that the **MAC algorithm need not be reversible**, as it must be for decryption.

MAC structure / diagram

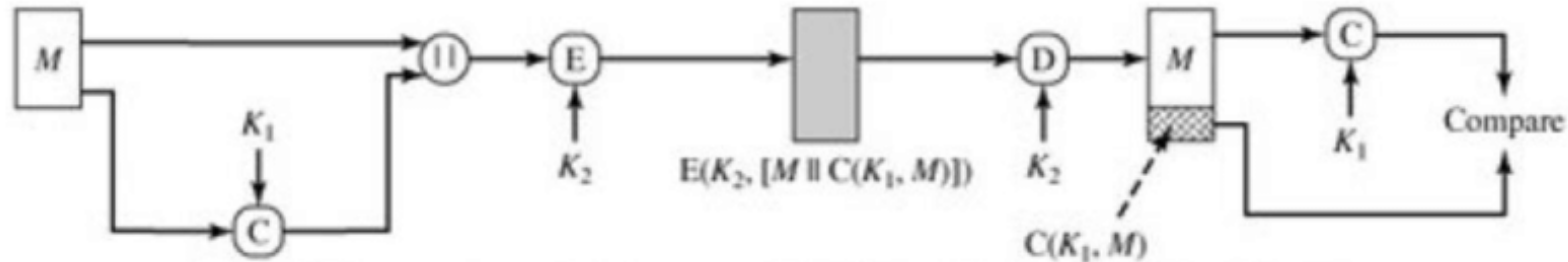


- $MAC = C(K, M)$
- where
 - $M = \text{input message}$
 - $C = \text{MAC function}$
 - $K = \text{shared secret key}$
 - $MAC = \text{message authentication code}$
- The message plus MAC are transmitted to the intended recipient.
- The recipient performs the same calculation on the received message, using the same secret key, to generate a new MAC.
- The received MAC is compared to the calculated MAC.
- If we assume that only the receiver and the sender know the identity of the secret key, and if the received MAC matches the calculated MAC, then

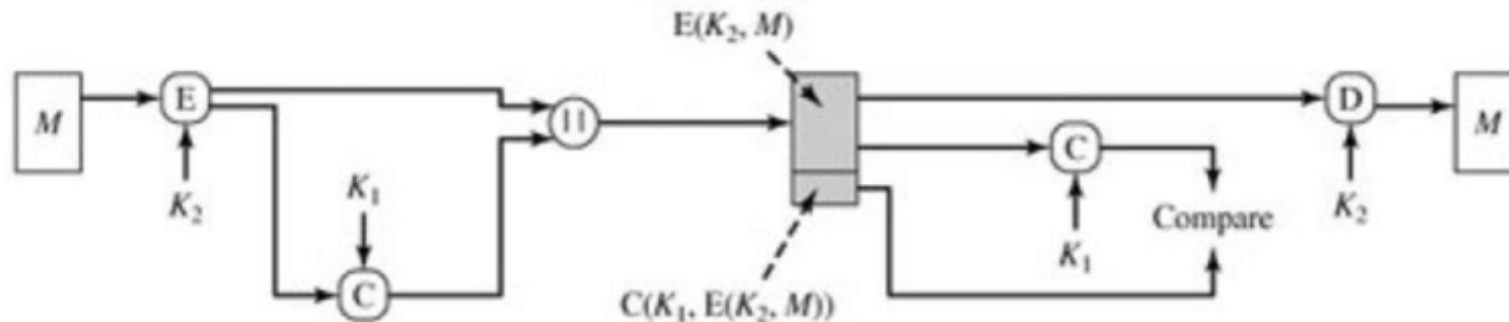
Basic Uses of Message Authentication code (MAC)



(a) Message authentication



(b) Message authentication and confidentiality; authentication tied to plaintext



(c) Message authentication and confidentiality; authentication tied to ciphertext

**Confidentiality,
Integrity and
Authentication is
achieved**